Readings:

- AWS KMS Best Practices
- Azure Confidential Computing
- GCP Encryption at Rest Whitepaper
- GCP Encryption in Transit Whitepaper
- GCP KMS Deep Dive
- Data Deletion on GCP
- AWS KMS Cryptographic Details
- Confidential Computing Consortium Outreach Whitepaper

Lecture 3: Encryption in the Cloud

Lucerne University of
Applied Sciences and Arts
HOCHSCHULE
LUZERN

Overview

- Encryption at rest
- Encryption in transit
- Encryption while processing
- Key management models
- Data deletion
- Data obfuscation

Encryption at Rest

- Target cloud protection should include all content stored at rest
- Data for storage typically split into chunks, and each chunk encrypted with a unique data encryption key (DEK)
- DEKs stored with data , encrypted / wrapped with key encryption key (KEK) exclusively stored and used inside central key management service (low latency, high availability, KEK not exportable from KMS)
- Encryption at storage level using AES256
- Crypto library (e.g. Google Tink, incorporating FIPS 140-2 (level 1) validated module, BoringCrypto) used across product range

Example Storage Classes

Save costs without sacrificing performance by storing data across different storage classes. Balance use and cost savings.

- Standard Storage: Good for “hot” data that’s accessed frequently, including websites, streaming videos, and mobile apps.
- Nearline Storage: Low cost. Good for data that can be stored for at least 30 days, including data backup and long-tail multimedia content.
- Coldline Storage: Very low cost. Good for data that can be stored for at least 90 days, including disaster recovery.
- Archive Storage: Lowest cost. Good for data that can be stored for at least 365 days, including regulatory archives.

GCP Storage Classes

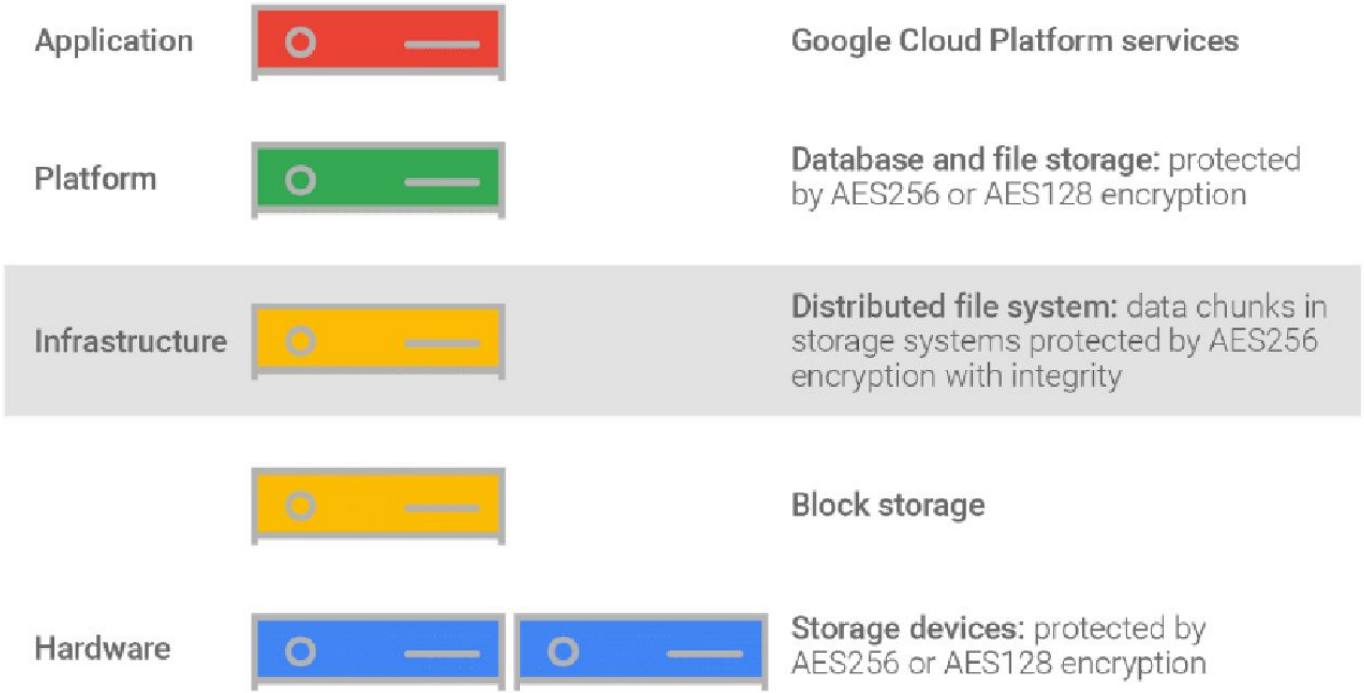
Storage Class	Name for APIs and gsutil	Minimum storage duration	Typical monthly availability[1]
Standard Storage	`STANDARD`	None	• >99.99% in multi-regions and dual-regions • 99.99% in regions
Nearline Storage	`NEARLINE`	30 days	• 99.95% in multi-regions and dual-regions • 99.9% in regions
Coldline Storage	`COLDLINE`	90 days	• 99.95% in multi-regions and dual-regions • 99.9% in regions
Archive Storage	`ARCHIVE`	365 days	• 99.95% in multi-regions and dual-regions • 99.9% in regions

https://cloud.google.com/storage/docs/storage-classes#standard

AWS Simple Storage Service (S3) Storage Classes

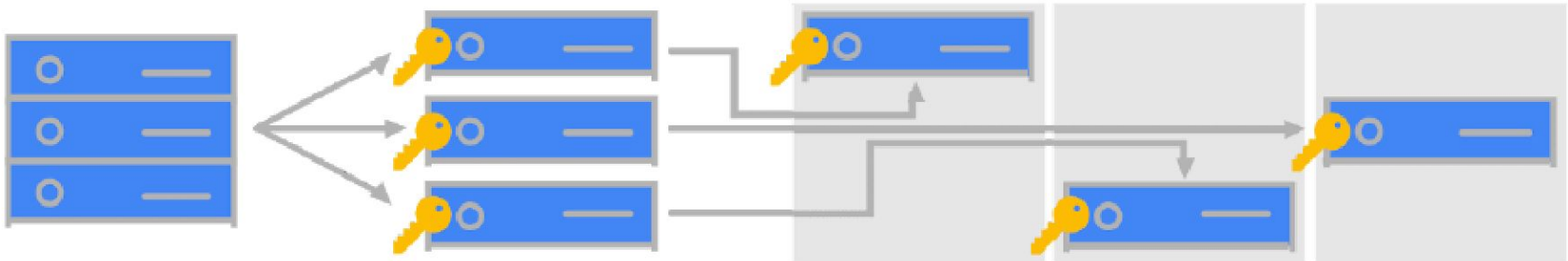
	S3 Standard	S3 Intelligent-Tiering*	S3 Standard-IA	S3 One Zone-IA†	S3 Glacier	S3 Glacier Deep Archive
Designed for durability	99.999999999% (11 9's)	99.999999999% (11 9's)	99.999999999% (11 9's)	99.999999999% (11 9's)	99.999999999% (11 9's)	99.999999999% (11 9's)
Designed for availability	99.99%	99.9%	99.9%	99.5%	99.99%	99.99%
Availability SLA	99.9%	99%	99%	99%	99.9%	99.9%
Availability Zones	≥3	≥3	≥3	1	≥3	≥3
Minimum capacity charge per object	N/A	N/A	128KB	128KB	40KB	40KB
Minimum storage duration charge	N/A	30 days	30 days	30 days	90 days	180 days
Retrieval fee	N/A	N/A	per GB retrieved	per GB retrieved	per GB retrieved	per GB retrieved

GCP Layers of Encryption



https://cloud.google.com/security/encryption-at-rest/default-encryption

GCP Distribution of Encrypted Chunks



https://cloud.google.com/security/encryption-at-rest/default-encryption

GCP Key Management Service (continued)



https://cloud.google.com/security/encryption-at-rest/default-encryption

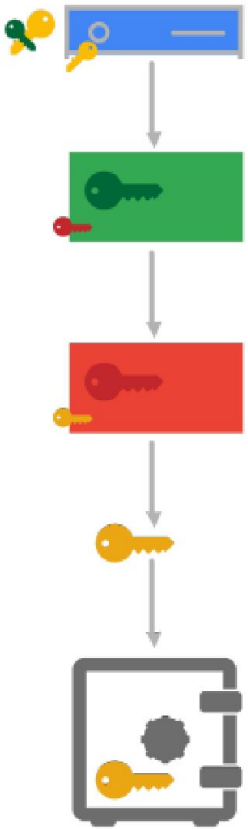
Generic Cloud Key Management Requirements

- Key generation
  - Create a new key or import from external source
- Key use
  - Keys accessible to services with authenticated access
- Key management
  - Manage keys which are active, authorize users or applications (rotation)
- Key revocation
  - Remove a key or access to the key
- Key deletion
  - Permanently remove key

GCP Key Management Service (KMS)

- Manages KEKs
- KEKs are not exportable by design: all encryption/ decryption must be done within KMS
- Automatic rotation of KEKs
  - Data is protected by a key set: one key active for encryption + a set of historical keys for decryption (number of which, determined by *key rotation schedule*)
  - Standard rotation period is 90 days, but can vary
  - Cloud Storage rotates its KEKs every 90 days (**re-wrapping**), can store up to 20 versions … requiring re-encryption of data at least every 5 years (**re-keying**)
- KMS-held keys are backed up for Disaster Recovery purposes, indefinitely recoverable
- Use of KEKs is managed by ACLs in KMS for each key, with a per-key policy
  - Only authorized services and users are allowed access to a key

GCP Encryption Key Hierarchy & Root of Trust



Storage
Data (encrypted with DEK)
DEK, almost always AES256
(wrapped with KEK)

KMS
KEK, either AES256 or AES128
(wrapped with KMS master key)

Root KMS
KMS master key, AES256
(wrapped with Root KMS master key)

Root KMS master key distributor
Root KMS master key, AES256

Physical safes
Root KMS master key, AES256

https://cloud.google.com/security/encryption-at-rest/default-encryption

GCP Data Backup

- Data remains encrypted through the backup process
- Backup system further encrypts each *backup file* independently with its own DEK derived from a key stored in the Key Management Service (KMS)
- Another DEK is used for all *metadata* in backups, also stored in the KMS

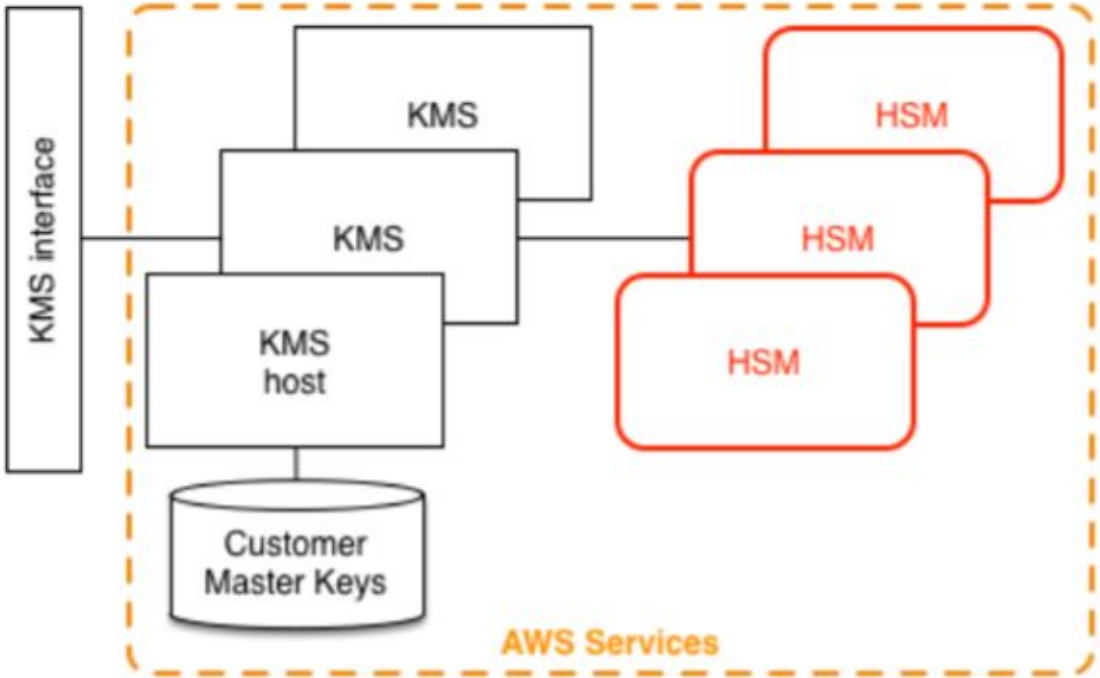
As a system generated and managed encryption process for backup, the key store ensure keys are kept available to enable recovery.

GCP Backup Encryption

AWS Backup Encryption

Azure Backup Encryption with CMEK

AWS Key Management Service Architecture



https://d0.awsstatic.com/whitepapers/KMS-Cryptographic-Details.pdf

AWS Key Management Concepts

- Customer Master Key (CMK):
  - A logical key that represents the top of your key hierarchy.
    - A CMK is given an Amazon Resource Name (ARN) that includes a unique key identifier, or key ID.
- Alias:
  - A user-friendly name, or alias, can be associated with a CMK.
  - The alias can be used interchangeably with key ID in many of the AWS KMS API operations.
- Permissions:
  - A policy attached to a CMK that defines permissions on the key.
  - Default policy allows any principals defined, as well as allowing the AWS account root user to add IAM policies that reference the key.
- Grants:
  - Grants are intended to allow delegated use of CMKs when the duration of usage is not known at the outset.
  - One use of grants is to define scoped-down permissions for an AWS service. The service uses your key to do asynchronous work on your behalf on encrypted data in the absence of a direct-signed API call from you.
- Data keys:
  - Cryptographic keys generated on HSMs under a CMK. AWS KMS allows authorized entities to obtain data keys protected by a CMK. They can be returned both as plaintext (unencrypted) data keys and as encrypted data keys.

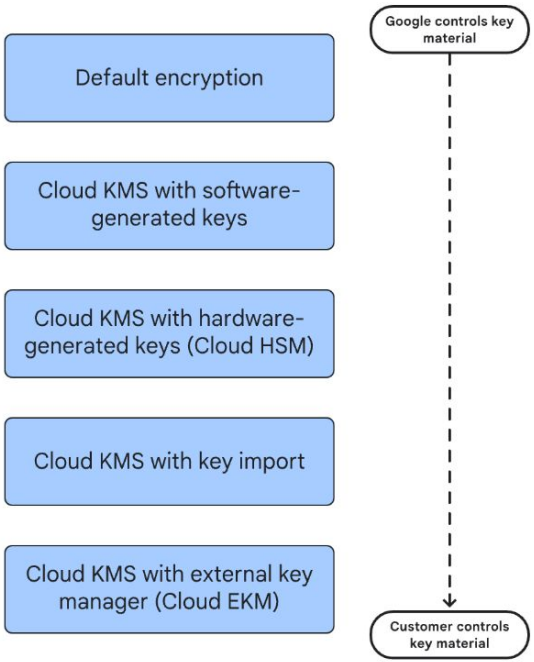
https://d0.awsstatic.com/whitepapers/KMS-Cryptographic-Details.pdf

AWS Key Hierarchy

Key	Description	Lifecycle
Domain key	A 256-bit AES-GCM key only in memory of an HSM used to wrap versions of the CMKs, the HSM backing keys.	Rotated daily[1]
HSM backing key	A 256-bit symmetric key only in memory of an HSM used to protect customer data and keys. Stored encrypted under domain keys	Rotated yearly[2] (optional config.)
Data encryption key	A 256-bit AES-GCM key only in memory of an HSM used to encrypt customer data and keys. Derived from an HBK for each encryption.	Used once per encrypt, and regenerated on decrypt
Customer data key	User-defined key exported from HSM in plaintext and ciphertext. Encrypted under an HSM backing key and returned to authorized users over TLS channel.	Rotation and use controlled by application

Example Crypto Key Options - GCP

The following diagram shows the Google Cloud portfolio for keys, arranged from Google-controlled key material to customer-controlled key material.



https://cloud.google.com/blog/products/identity-security/new-google-cloud-whitepaper-cloud-key-management-service
https://storage.googleapis.com/gweb-cloudblog-publish/images/current_google_cloud_portfolio.max-2800x2800.jpg
https://cloud.google.com/docs/security/key-management-deep-dive

Cloud Key Models Compared -- Exercise

EXERCISE FOR YOU: COMPLETE THE TABLE!

	Provides default encryption	Cloud Key Management service	HSM support? On prem / on cloud / CoLo	Import of own keys	External Key Management (EKM)
Alibaba Cloud					
AWS					
Azure					
Google Cloud					
Huawei Cloud					
Tencent Cloud					

Example Product Positioning

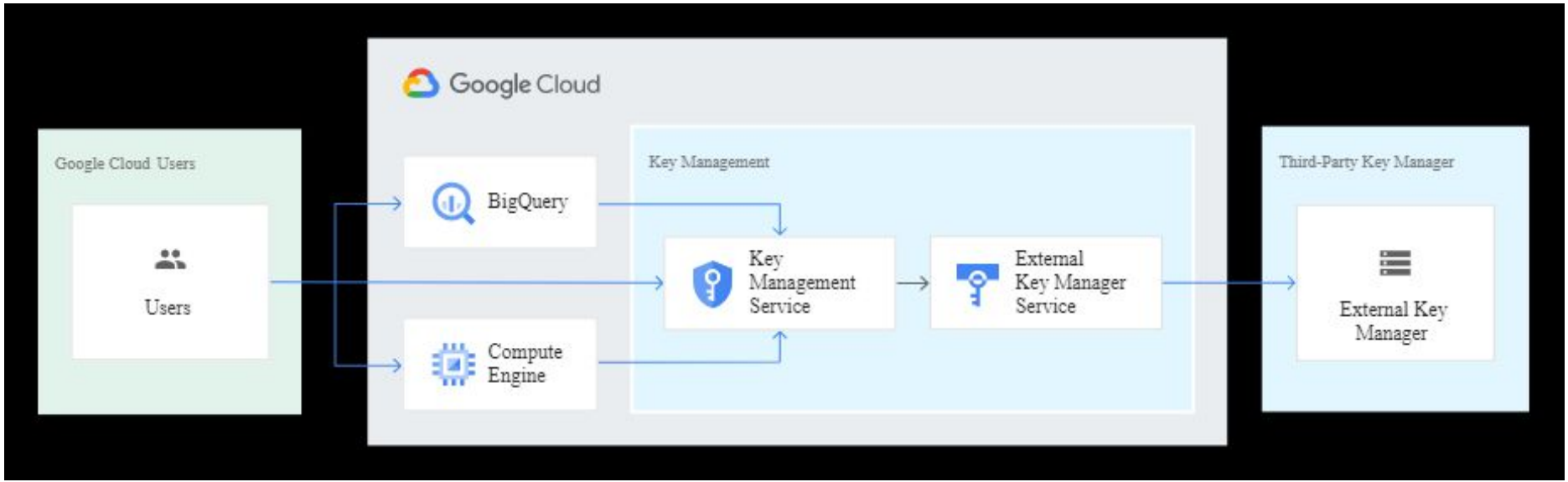
- Enhanced crypto key management
- HSM options
- In-cloud or external options
- BYOK

See for example:
https://learn.microsoft.com/en-us/azure/key-vault/keys/hsm-protected-keys-nciphe

https://learn.microsoft.com/de-de/azure/key-vault/keys/hsm-protected-keys-ncipher



External Key Management Service



Quiz 5

- What generic operations would you expect from a cloud KMS?
- What are the DEK and KEK in Google Cloud platform, and how do these work together?
- What is the difference between EKM and HSM?

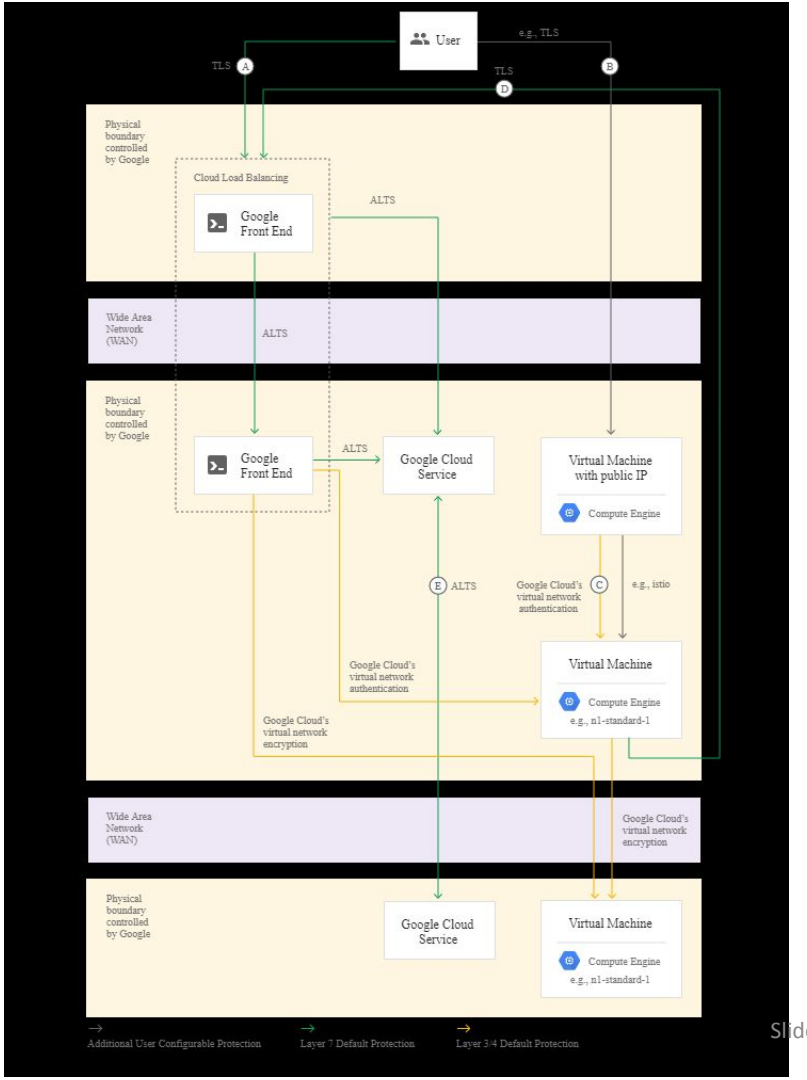


Encryption in Transit

- Links to large ISPs can mean that hops across the public Internet are limited and transit can happen on CSP network
- Front end servers typically implement strong encryption protocols such as TLS to secure connections between customer devices and the CSP web services and APIs
- Interconnect with Cloud Service Provider:
  - VPN over internet using IPSec
  - Direct Peering – private connection between enterprise and CSP for hybrid cloud workloads
  - Carrier peering – connection through largest partner network of service providers
  - Dedicated interconnect. Connect N x 10Gbps transport circuits for private cloud traffic to CSP at CSP POPs (99.99 % SLA)

Cloud Service Comms

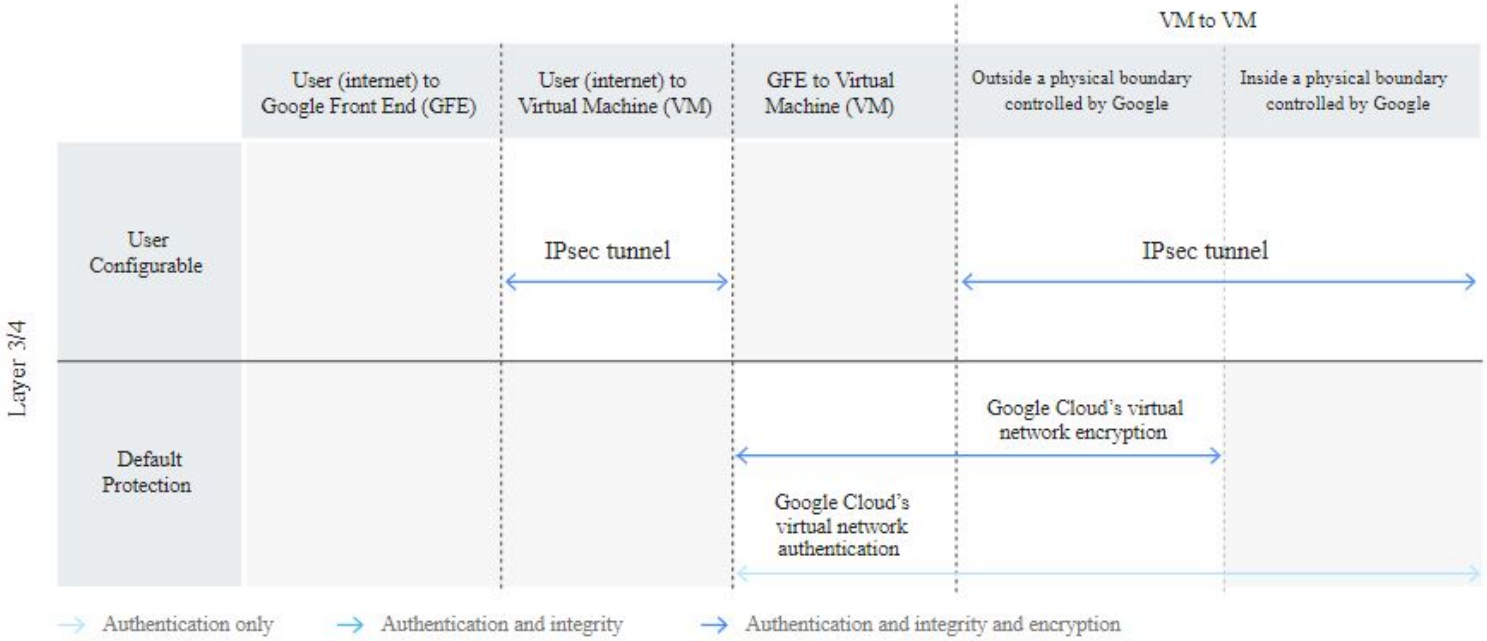
- Routing from one production service to another traverses network backbone
- May require routing traffic outside physical boundaries controlled by CSP (see label E).
- An example of this kind of traffic is a Cloud Storage event triggering Cloud Functions.
- Connections between production services are encrypted if they leave a physical boundary, and authenticated within the physical boundary.



Lucerne University of Applied Sciences and Arts
HOCHSCHULE LUZERN

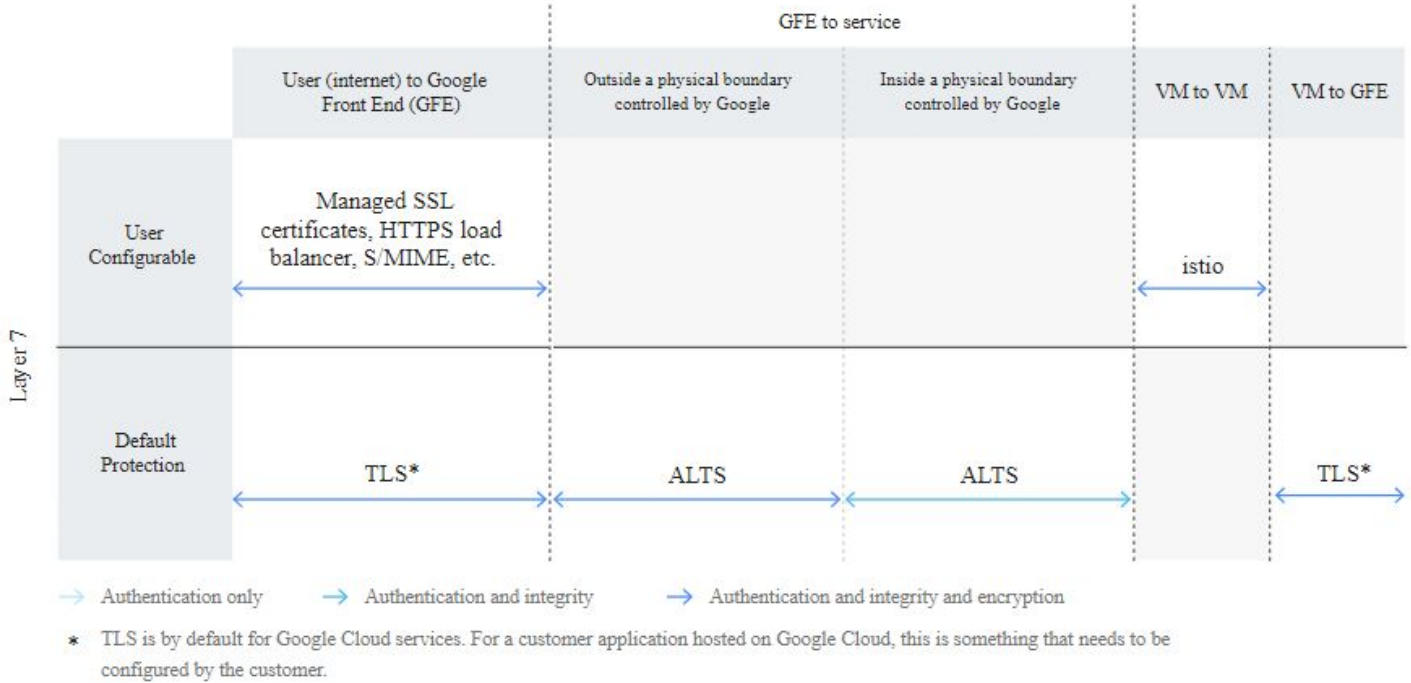
https://cloud.google.com/security/encryption-in-transit

GCP Encryption in Transit by Default (Layers 3/4)



https://cloud.google.com/security/encryption-in-transit

GCP Encryption in Transit by Default (Layer 7)



https://cloud.google.com/security/encryption-in-transit

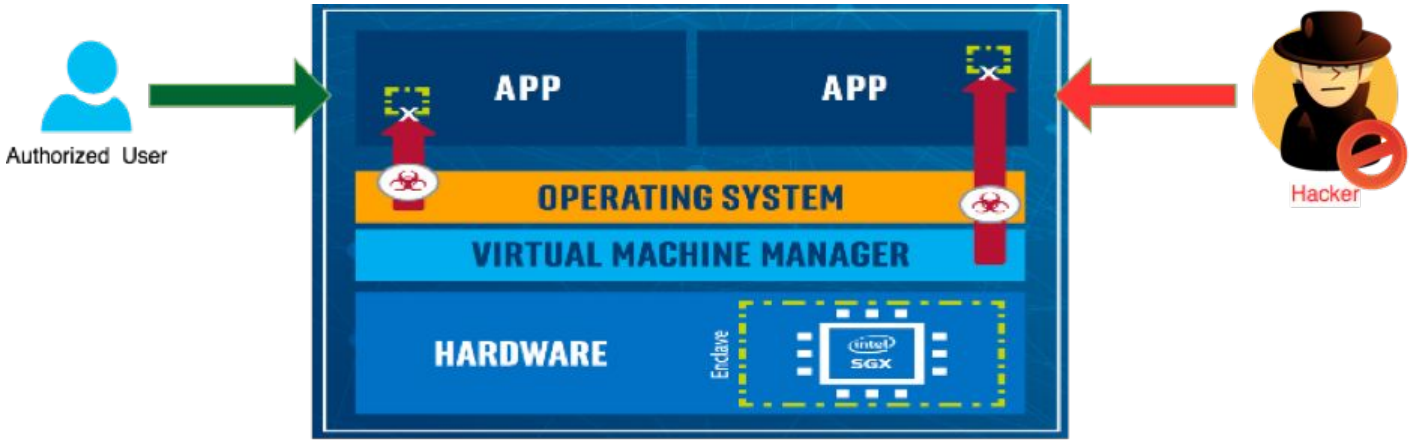
Encryption while Processing



- Confidential VMs use memory encryption to further isolate workloads and tenants from each other, and from the cloud infrastructure.
- Provide an easy-to-use option, for both lift-and-shift and newly created workloads, to protect the memory of workloads
- In Google Compute Engine Confidential VMs offer high performance for computational tasks, while keeping VM memory encrypted with a dedicated per-VM instance key that is generated and managed by an AMD secure processor embedded within AMD EPYC processors.
- Confidential VMs can scale to 240 vCPUs and 896 GiB memory, and can be used without significant performance degradation.

IBM Cloud Confidential Compute

- Based on Intel SGX



https://www.europeclouds.com/blog/confidential-computing-and-the-public-cloud

Azure Confidential Computing

- Safeguard data from malicious and insider threats while it's in use
- Maintain control of data throughout its lifetime
- Protect and validate the integrity of code in the cloud
- Ensure that data and code remain outside the view of the cloud platform provider

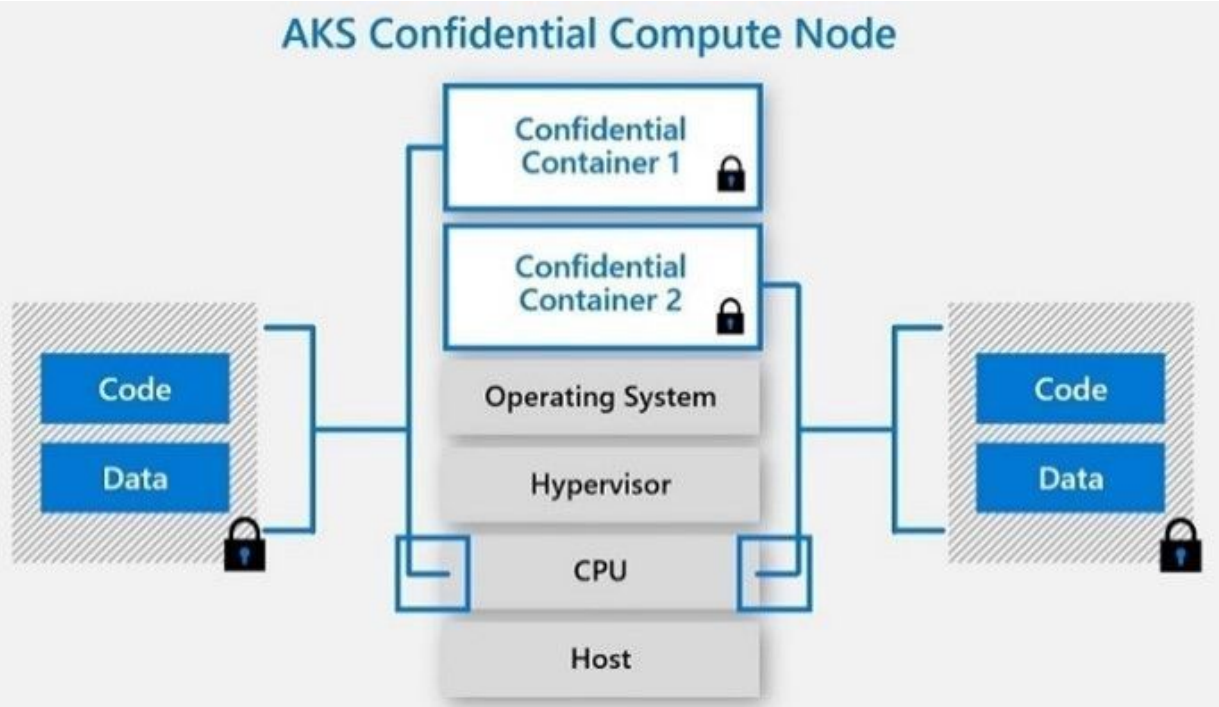
https://azure.microsoft.com/en-us/solutions/confidential-compute/

Azure Confidential Computing TEEs

- Confidential computing is the protection of data-in-use through isolating computations to a hardware-based trusted execution environment (TEE).
- A TEE provides a protected container by securing a portion of the hardware's processor and memory.
- Software can be run on top of the protected environment to shield portions of the code and data from view or modification from outside of the TEE.

https://azure.microsoft.com/en-us/solutions/confidential-compute/

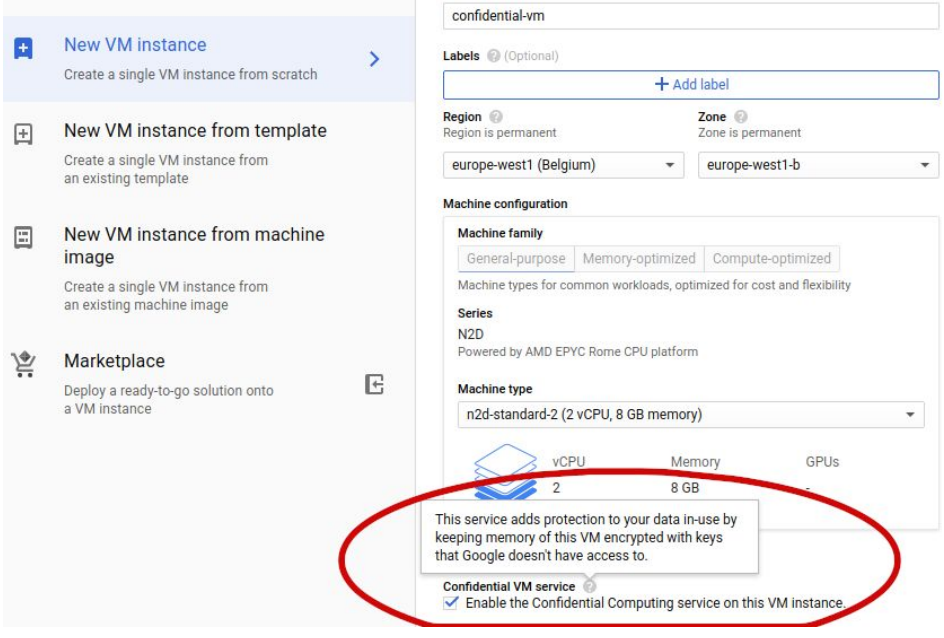
Azure Kubernetes Service (AKS) Confidential Computing Node

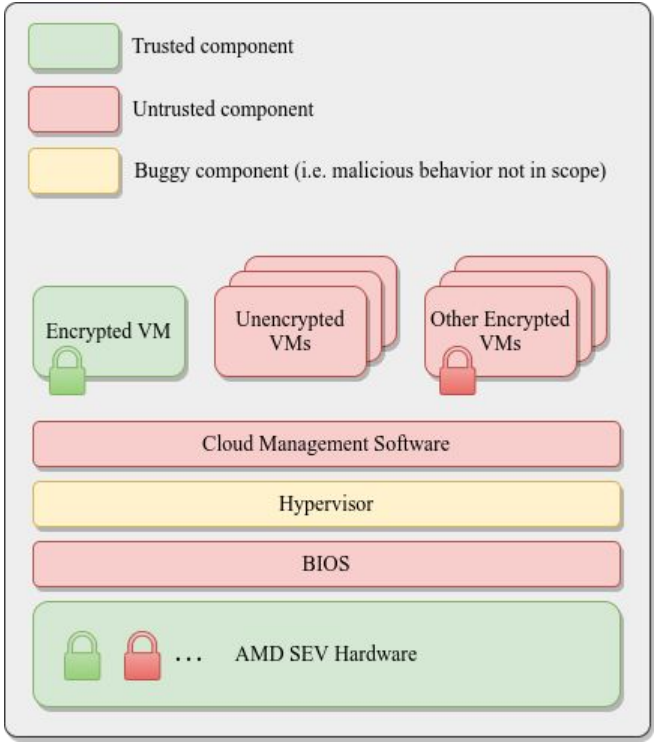


https://www.europeclouds.com/blog/confidential-computing-and-the-public-cloud

GCP Confidential Compute

- GCE or GKE
- AMD EPYC Processor (Rome Series) Secure Encrypted Virtualization (SEV)





https://medium.com/google-cloud/confidential-computing-is-cool-1d715cf47683

GCP Data Deletion



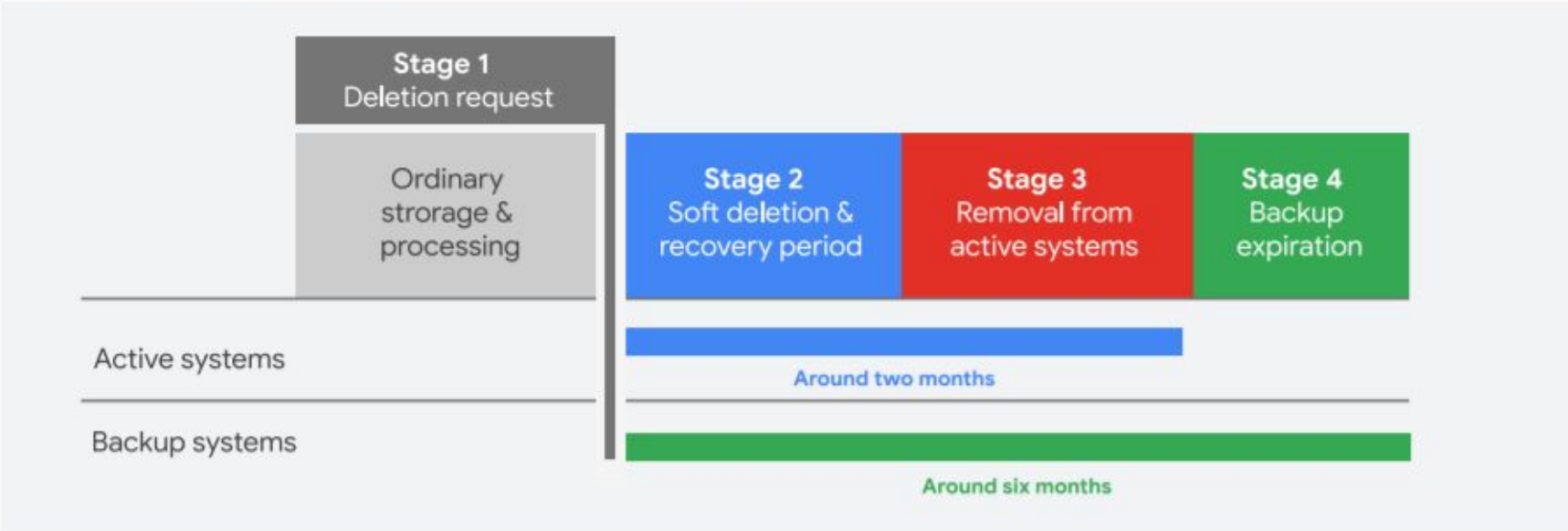
- On GCP if customers delete their data it is fully deleted from systems within 180 days
- Google hard drives protect data at rest with technologies like Full Disk Encryption (FDE) and drive locking.
- When a drive is retired, authorized individuals verify the disk is erased by writing zeros to the disk / verifying.
- If drive cannot be erased, it is physically destroyed with a crusher to deform the drive and then shredded.
- See end-to-end deletion process white paper

https://cloud.google.com/docs/security/deletion
https://services.google.com/fh/files/misc/data_deletion_on_gcp.pdf

https://cloud.google.com/privacy/gdpr

https://www.youtube.com/watch?v=WB6xrgI9eGk&autoplay=1

Stages of GCP deletion pipeline

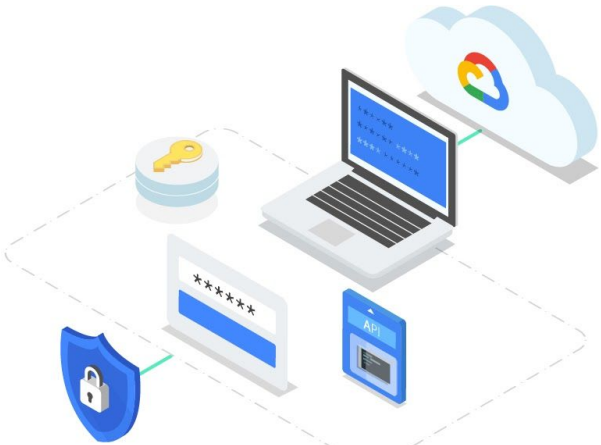


https://services.google.com/fh/files/misc/data_deletion_on_gcp.pdf

Secrets Management

For info on **AWS Secrets Manager**: see https://aws.amazon.com/secrets-manager/

- Google Secrets Manager
  - Store API keys, passwords, certificates and other sensitive data
  - A central place & single source of truth to manage, access & audit secrets across Google Cloud
  - Connection to cloud secured using TLS
  - Unique Data Encryption Key (DEK) generated to encrypt secret
  - DEK is encrypted with a cloud KMS, controlled by Secret Manager, and stored
  - Automatic replication (to regions chosen by Google) or User Managed (pick one or more regions in which to store. Replication handled Google)



https://cloud.google.com/secret-manager

Quiz 6

- What network / security options could you consider to protect data between a cloud provider and the on-premises environment?
- What is the point of a secrets manager?
- Why is deletion of data an issue for cloud use?



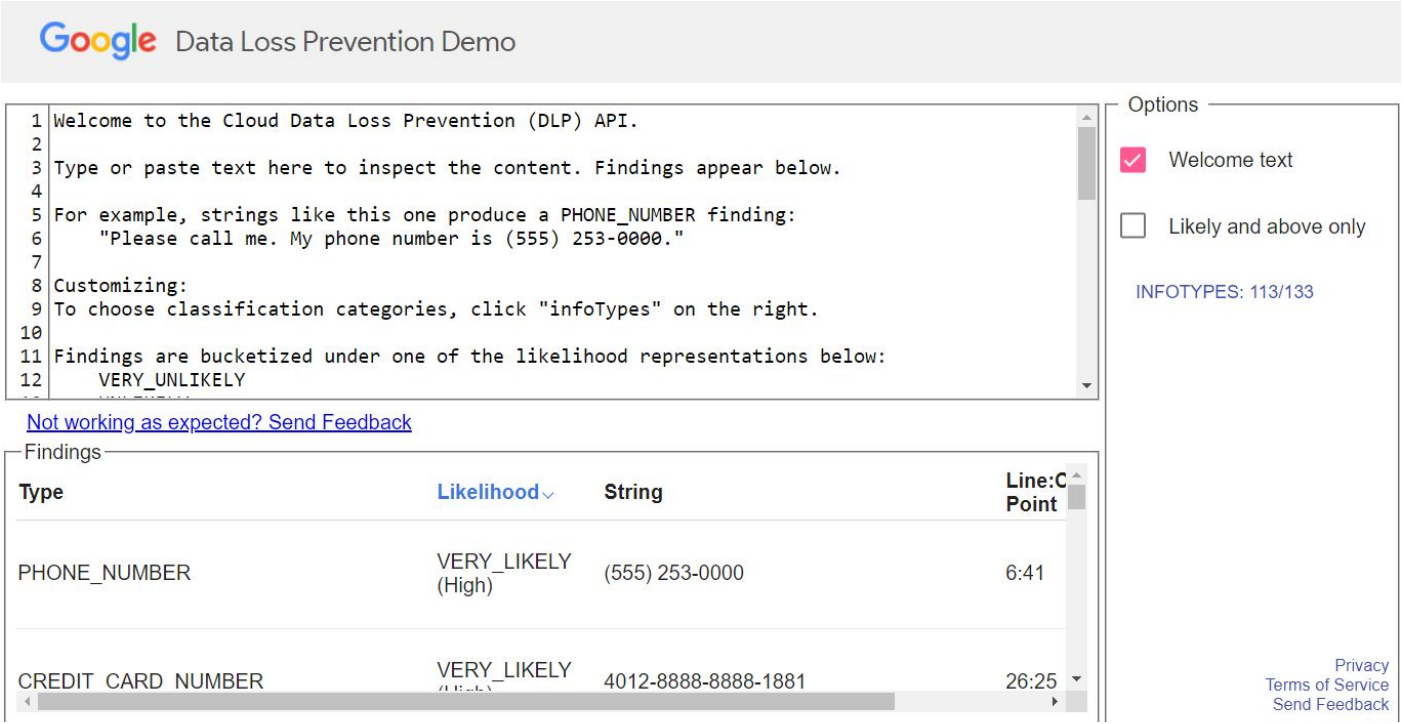
Data Obfuscation

- Anonymization
- Pseudonymization
  - 'Pseudonymisation' means the processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person.

    https://cpl.thalesgroup.com/faq/data-protection-security-regulations/what-pseudonymisation
- Tokenization
  - Tokenization substitutes sensitive data with surrogate values called tokens, which can then be used to represent the original (or raw) sensitive value.

https://cloud.google.com/blog/products/identity-security/take-charge-of-your-data-how-tokenization-makes-data-usable-without-sacrificing-privacy

DLP Demo



See: https://cloud.google.com/dlp/demo/#!/

Protection of Personal Information





"I can't explain it—it's just a funny feeling that I'm being Googled."

© The New Yorker Collection 2002 Charles Barsotti from cartoonbank.com. All Rights Reserved.